STRIPE AI INFRASTRUCTURE • CERTIFICATION BLOC 2 (RNCP 41993)

# Sécurité, Gouvernance Multi-Juridictions, Audit Automatisé & FinOps

En tant qu'opérateur financier mondial, Stripe se conforme simultanément aux trois cadres réglementaires majeurs couvrant ses flux européens et nord-américains : - **PCI-DSS v4.0 Level 1 (Payment Card Industry Data Security Standard) :** Isolation stricte des données de cartes bancaires (PAN, CVV, code PIN), chiffrement fort et traçabilité immuable des accès. - **RGPD (Règlement Général sur la Protection des Données — UE) :** Souveraineté territoriale en Europe ( `eu-west-3` Paris), minimisation, pseudonymisation SHA-256 et droit à l'oubli (Article 17) sous 30 jours. - **CCPA / CPRA (California Consumer Privacy Act — USA) :** Respect du droit d'accès, du droit à l'effacement sous 45 jours (*Right to Delete*) et du droit d'opposition au partage analytique/commercial (*Right to Opt-Out of Sale or Sharing*) pour les résidents californiens.

### 1.1. Architecture "Tokenization Vault" & Isolation PCI-DSS

Pour réduire drastiquement le périmètre d'audit PCI (*PCI Scope Reduction*), aucun numéro de carte bancaire (PAN) ne pénètre dans les bases applicatives (OLTP, OLAP, NoSQL ou Data Lake) : 1. **Interception à l'Edge :** Les formulaires Stripe Checkout / Elements injectent les données de carte directement dans un **coffre-fort de tokenisation isolé** certifié PCI-DSS Level 1 (VPC dédié chiffré par module matériel **AWS CloudHSM** FIPS 140-2 Level 3). 2. **Émission d'un Token non réversible :** Le coffre-fort renvoie un jeton opaque ( `pm_1J8x92...` ) et les 4 derniers chiffres ( `card_last4` ). 3. **Zéro PAN dans les logs :** Des règles au niveau d'AWS WAF et des agents Fluentbit masquent systématiquement toute chaîne numérique de 13 à 19 chiffres passant le contrôle de Luhn.

### 1.2. Chiffrement de Bout en Bout, RBAC & Gestion des Secrets

- **Chiffrement en Transit :** 100% des communications externes et inter-microservices exigent **TLS 1.3** (rejet de tout flux en clair).
- **Chiffrement au Repos :** Tous les volumes (EBS, Aurora, DocumentDB, Redshift, MSK, S3) sont chiffrés via **AWS KMS avec des clés gérées par le client (CMK)** en **AES-256** et rotation annuelle automatique.
- **Contrôle d'Accès RBAC & Moindre Privilège :** Accès cloisonnés par rôle métier via **AWS IAM / IRSA** (*IAM Roles for Service Accounts*) sur EKS (zéro mot de passe en clair) et rotation automatique des secrets DB tous les 30 jours via **AWS Secrets Manager**. Les accès administratifs passent exclusivement par **AWS Systems Manager Session Manager avec MFA** (zéro port SSH exposé).

## 2. Matrice des Risques, Mesures & Responsabilités

| Risque Identifié | Impact Métier | Mesure de Protection Architecturale | Référence / Norme | Responsable Désigné |
|---|---|---|---|---|
| **Fuite de données de cartes (PAN/CVV)** | Catastrophique (perte d'agrément bancaire, amendes majeures) | Coffre-fort de tokenisation dédié (CloudHSM), zéro PAN dans l'infrastructure Data, masquage WAF & Fluentbit. | PCI-DSS v4.0 (Req 3 & 4) | CISO |
| **Accès illégitime ou élévation de privilèges** | Majeur (altération de soldes, exfiltration de données marchands) | Principe du moindre privilège RBAC via AWS IAM/IRSA, contrôle colonne/ligne sur Redshift, zéro port SSH ouvert. | PCI-DSS (Req 7 & 8) / ISO 27001 | Lead Cloud Security Engineer |
| **Non-conformité RGPD & CCPA** | Élevé (amendes CNIL jusqu'à 4% du CA mondial / sanctions CPPA) | Pseudonymisation `email_hash` SHA-256 avec sel, région souveraine `eu-west-3` (UE) / `us-west-2` (US), propagation drapeau `do_not_sell_or_share`, orchestrateur d'effacement. | RGPD Art. 17 & 32 / CCPA §1798 | Data Protection Officer (DPO) |
| **Perte de données sur panne datacenter** | Majeur (interruption d'activité, perte financière) | Aurora Multi-AZ sur 3 AZs (6 copies synchrones, RPO=0), Aurora Global Database DR cross-région, sauvegardes S3 Object Lock. | Continuité d'activité / BCP | Lead DBA |
| **Attaque DDoS sur l'Edge** | Moyen à Élevé (indisponibilité Checkout) | AWS Shield Advanced + AWS WAF (*rate limiting* à 2000 req/5min/IP). | SLA 99.999% | Network & Infra Lead |
| **Altération des logs d'audit** | Majeur (impossibilité d'investigation légale) | AWS CloudTrail consolidé en Bucket S3 dédié avec *Log File Validation* et verrouillage immuable WORM. | PCI-DSS (Req 10) | Responsable Audit & Conformité |

## 3. Conformité RGPD (Droit à l'Oubli) & CCPA (*Opt-Out* / *Right to Delete*)

Pour arbitrer proprement entre le droit à l'effacement et les lois comptables bancaires :

1. **Traitement des demandes d'effacement (RGPD Art. 17 < 30j & CCPA < 45j) :**
2. **Couche OLTP (Aurora) :** L'orchestrateur Airflow exécute la pseudonymisation irréversible de l'entité `Customer` (`email_hash` purgé vers valeur aléatoire `DELETED_USER_XXXX`, suppression IP client). Les écritures comptables (`Transaction`) demeurent intactes sous ID pseudonyme pendant **10 ans** afin de respecter le Code de commerce et les audits fiscaux.
3. **Couches NoSQL & Data Lake :** L'événement sur le topic `stripe.gdpr_ccpa.requests` déclenche la suppression immédiate des documents associés dans DocumentDB (`device_fingerprints`, `clickstream_events`, `customer_feedback`) et la réécriture/purge des partitions Parquet S3 impactées (Iceberg / Delta delete).

4. **Gestion du *Right to Opt-Out* CCPA ( `do_not_sell_or_share` ) :**
   Dès qu'un consommateur californien active son refus de partage/profilage commercial, le drapeau `do_not_sell_or_share = true` est propagé en temps réel vers Aurora, DocumentDB et Redshift ( `DimCustomer` ). Tous les modèles de personnalisation marketing/recommandation et pipelines d'export BI excluent automatiquement ces profils via une politique de filtrage natif (*Row-Level Security*).

---

## 4. Plan de Surveillance Continue & Reporting Automatisé de la Conformité

La conformité n'est pas auditée manuellement une fois par an : elle est **vérifiée en continu par code et automatisée** :

1. **Contrôle Continu de Configuration (*AWS Config Rules & Security Hub*) :**
   Plus de 80 règles automatisées contrôlent en permanence le respect des standards **PCI-DSS v4.0**, **CIS AWS** et **RGPD** : vérification que tout nouveau bucket S3 bloque l'accès public, que tout volume EBS/RDS est chiffré KMS, et qu'aucun Security Group n'ouvre un port critique vers `0.0.0.0/0` . Toute dérive déclenche une alerte EventBridge vers PagerDuty et une auto-remédiation Lambda en moins de 60 secondes.
2. **Détection Automatisée de PII/PAN par IA (*Amazon Macie*) :**
   Des jobs **Amazon Macie** planifiés scannent quotidiennement les couches **S3 Bronze & Silver** afin de détecter toute fuite accidentelle d'emails non hachés, numéros de sécurité sociale ou séquences à 16 chiffres ressemblant à des cartes bancaires.
3. **Reporting & Piste d'Audit Unifiée (*AWS Audit Manager & FactComplianceAudits*) :**
   Chaque action de conformité (purge RGPD réussie, activation opt-out CCPA, rotation de clé KMS tous les 30/365 jours, blocage WAF/Macie) est journalisée vers le Data Warehouse OLAP dans `FactComplianceAudits` et archivée avec preuves cryptographiques dans un coffre S3 WORM (*Object Lock*). Le DPO et les auditeurs QSA PCI-DSS disposent d'un tableau de bord temps réel mesurant les taux de conformité et SLA légaux.

---

## 5. Analyse Économique (FinOps) & Estimation Budgétaire AWS

Une estimation budgétaire a été réalisée sur l'**AWS Pricing Calculator** pour dimensionner l'infrastructure européenne traitant 15 millions de transactions par jour :

| Service AWS | Rôle dans l'Architecture | Dimensionnement / Type | Coût Estimé / Mois | % Facture |
|---|---|---|---|---|
| **Amazon Aurora PostgreSQL** | Base de données OLTP Multi-AZ | `db.r6i.4xlarge` (16 vCPU, 128 Go RAM) + 2 Réplicas + 2 To io2 | ~7 500 $ | 30 % |
| **Amazon Redshift Serverless** | Data Warehouse OLAP & BI | 128 RPU (base) avec mise à l'échelle automatique | ~4 200 $ | 17 % |
| **Amazon EKS & Inférence IA** | Pods FastAPI Radar & Checkout | 12 instances `c6i.2xlarge` réparties sur 3 AZs | ~3 800 $ | 15 % |
| **Amazon MSK (Kafka)** | Bus d'événements de streaming | 3 brokers `kafka.m5.2xlarge` (Multi-AZ) + EBS chiffré | ~2 600 $ | 10 % |
| **Amazon DocumentDB & Redis** | NoSQL & Feature Store Feast | DocumentDB `db.r6g.xlarge` + Redis Cluster (3x `cache.r6g.xlarge`) | ~2 400 $ | 10 % |
| **Amazon S3 & S3 Glacier** | Data Lake Bronze/Silver/Gold & Vault | 150 To S3 Standard + 400 To Glacier Flexible Archive | ~1 900 $ | 8 % |
| **Réseau, WAF, Security Hub & Macie** | ALB, NAT Gateways (x3), Sécurité | Transfert inter-AZ, WAF, Audit Manager & scan Macie | ~1 500 $ | 6 % |
| **Amazon SageMaker & GPU** | Réentraînement batch ML | Instances GPU Spot éphémères (`ml.g5.2xlarge`, 8h/sem) | ~1 100 $ | 4 % |
| **TOTAL ESTIMÉ** | **Infrastructure Complète** | **Haute Disponibilité 3-AZ Région Paris** | **~25 000 $** | **100 %** |

### Les 3 Leviers d'Optimisation FinOps :

1. **RDS Savings Plans sur 3 ans (Aurora) :** Réduit le coût de calcul du socle 24/7 de **38%** (-2 850 $/mois).
2. **Instances GPU Spot éphémères (SageMaker) :** Économie de **70%** sur les réentraînements hebdomadaires + auto-scaling EKS (HPA de 30 pods en pic vers 3 pods la nuit).
3. **Usage Limits Redshift & TTL NoSQL :** Plafonnement RPU nocturne sur Redshift Serverless, index TTL 90 jours sur DocumentDB et bascule automatique vers S3 Glacier.

---

## 6. Note d'Ingénierie Écologique (GreenOps)

1. **Région Bas-Carbone (`eu-west-3` Paris) :** Mix électrique français à très faible intensité carbone (**~50 à 60 g $CO_2$e/kWh**) contre > 380 g $CO_2$e/kWh à Francfort ou en Virginie du Nord.
2. **Zéro Compute "Zombie" (Anti-Idle Pattern) :** Les clusters GPU SageMaker ne sont provisionnés qu'au lancement exact du DAG Airflow et détruits dès l'export ONNX vers MLflow/S3.
3. **Compaction & Compression Optimale :** Conversion systématique au format colonne **Apache Parquet (Snappy/ZSTD)** divisant par 4 l'empreinte disque et les transferts réseau.